IIIT BANGALORE · ADVANCED EXECUTIVE PROGRAM IN CYBERSECURITY

Executive Summary — VAPT Course-End Project

Vulnerability Assessment and OS Command Injection Exploitation on Linux Web Servers (Bee-Box / bWAPP Platform)

STUDENT	PROGRAM	TARGET	DATE
Subham Dey	AEP Cybersecurity	Bee-Box v1.6 (192.168.140.132)	24–25 Oct 2026

This engagement presents a controlled vulnerability assessment and ethical hacking exercise conducted against the deliberately vulnerable Bee-Box (bWAPP) platform. The assessment followed a structured five-task methodology: environment setup, vulnerability scanning with Nmap and Nikto, SNMP exploitation using Metasploit, anonymous FTP access verification, and service hardening. The target exhibited a severely weakened security posture consistent with an unpatched 2008-era Ubuntu build, exposing 17 TCP services, 1 UDP service (SNMP), and 24 distinct web vulnerabilities including a critical plaintext credential leak.

3	6	2	1
CRITICAL	HIGH	MEDIUM	LOW

Project Tasks Completed

TASK	ACTIVITY	KEY RESULT	STATUS
Task 1	Environment Setup	Bee-Box deployed at 192.168.140.132; connectivity validated via ping	DONE
Task 2	Vulnerability Scanning	17 open TCP ports, 1 UDP port (SNMP), 24 Nikto findings including #wp-config.php# credential leak	DONE
Task 3	SNMP Exploitation	Full host MIB extracted via Metasploit; default communities public (RO) and private (RW) confirmed valid	DONE
Task 4	Anonymous FTP Access	Unauthenticated login successful (code 230); complete file listing retrieved	DONE
Task 5	FTP Hardening	Anonymous block disabled in proftpd.conf; re-test confirmed 530 Login incorrect	DONE

CRITICAL FINDINGS

- Anonymous FTP login granted without credentials (code 230)
- SNMPv1 default communities public and private both valid
- #wp-config.php# swap file exposes database credentials over HTTP

KEY SERVICES ENUMERATED

- FTP (ProFTPD 1.3.1), SSH (OpenSSH 4.7p1), SMTP (Postfix)
- HTTP/HTTPS (Apache 2.2.8 / PHP 5.2.4 / OpenSSL 0.9.8g)
- Samba 3.0.28a, MySQL 5.0.96, VNC 3.8, nginx 1.4.0
- Legacy r-services (rexecd, rlogin, rsh) exposed

Most Significant Discovery

SNMP enumeration using the default community string "public" extracted the complete host MIB, revealing hidden listening ports (3632/distccd, 9443) and root-owned processes (Xvnc, distccd) that were invisible to external TCP scanning. This demonstrates that SNMP exposure constitutes a critical intelligence leak, effectively providing an attacker with internal network visibility without requiring authenticated access.

REMEDIATION APPLIED

- Disabled <Anonymous ~ftp> block in /etc/proftpd/proftpd.conf
- Restarted ProFTPD service and verified 530 rejection

OS COMMAND INJECTION MITIGATION

- Input validation using allow-list regex for hostnames
- Pass arguments as arrays (shell=False) to prevent injection

- Anonymous access blocked; authenticated access preserved

- Use escapeshellarg() when shell execution is unavoidable
- Run services with least privilege; disable legacy daemons

Conclusion

All five mandated tasks were completed and evidenced. The engagement demonstrates that vulnerability assessment is not merely about identifying open ports, but understanding how default credentials, legacy services, and unsanitised input paths cascade into full system intelligence disclosure. The anonymous FTP vulnerability was successfully remediated and verified, while the remaining findings are documented with severity ratings, MITRE ATT&CK mappings, and D3FEND countermeasures for future hardening.